ITA1405
Ethical Hacking

K. Namitha
192311205

CO1-AT3

① A company Authorized Network Testing but does not define the scope. you discover a critical vulnerability outside the Authorized System. would you exploit it to prove impact? justify your answer using ethical Hacking Principles.

Ethical hacking is the process of identifying security aweaknesses in computer systems, networks and applications with proper authorization. its main objective is to improve security by discovering vulnerabilities before malicious attackers exploit them.

Ethical hackers must follow professional ethics, legal requirements, confidentiality, and agreed scope of testing. Even when a vulnerability is critical, an ethical hacker cannot automatically assume permission to exploit it.

Problem :-

In this scenario, a company hires me to test its network but provides only a one-line email authorization without clearly defining the scope. During testing, I discover a critical vulnerability in a system that was not mentioned in the authorization.

The main issues are:-

* The authorization does not clearly identify the systems that can be tested
* The newly discovered vulnerability belongs to a system outside the defined scope.
* Exploiting the vulnerability may affect business operations or expose confidential information.

Ethical Hacking principles:-

a) Authorization and permission

Written authorization is the foundation of ethical hacking. Before testing begins, the client must clearly approve the activities and systems involved

b) Defined scope

The scope specifies which IP addresses, servers, applications, networks, and other assests can be tested. it should also state the permitted testing techniques and any prohibited activities.

c) Non-maleficence and minimizing harm

Ethical hackers must avoid causing unnecessary harm. Exploiting a critical vulnerability may affect other systems or interrupt services.

d) confidentiality and privacy

If the vulnerability reveals sensitive information, I would avoid collecting or sharing unnecessary data. Evidence would be stored securely and disclosed only to authorized persons.

e) Responsible disclosure

Responsible disclosure means reporting a security weakness to the appropriate authority in a controlled and timely manner. I would communicate the vulnerability, its potential impact, the affected asset if known and the need for further authorized investigation.

(2) You discover SQL injection in a production Database containing Real customer financial Data. How would you proceed without causing Harm, and what Precautions should Have Been Taken Before the Engagement Began?

SQL injection is a security vulnerability that occurs when an application handles user input unsafely while constructing database queries. An attacker may manipulate a query to access information or perform database operations that should not be permitted.

Penetration testing helps organizations identify SQL injection vulnerabilities before malicious attackers exploit them. However when a production database contains real customer financial information, the tester must prioritize data protection, privacy, and business continuity.

Problem understanding :-

In this scenario, i am conducting an authorized test. During testing, I discover that the client's production database contains real customer financial information, and my test plan includes exploiting a SQL injection vulnerability.

The main corners are :-

* unauthorized exposure of customer financial records.
* Accidental modification or deletion of database information
* interruption of important business services.
* violation of customer privacy and applicable data-protection requirements.

Procedure without causing Harm:

a) Stop potentially harmful testing

As soon as I realize that the database contains real financial information, I would pause any test that would expose, modify, or delete customer records. I would review the approved test plan and clarify whether the planned exploitation method is permitted in a production environment.

b) Notify the authorized client representative

I would inform the clients designated security contact about the presence of sensitive financial information and the identified SQL injection risk. I would explain the possible impact and agree on a safe verification method before proceeding

c) Protect collected evidence

I would record the affected application, the relevant test input, the observed response, and the potential impact. Evidence should contain only the minimum information necessary to demonstrate the finding

Precautions Before engagement Began

* obtain written authorization
* Define the Scope and rules of engagement
* identify sensitive information
* Establish a safe testing environment
* Prepare backups and recovery procedures
* Agree on incident reporting procedures.

③ During a Black box penetration Test. you Accidentally Trigger a Denial-of-service condition on a Live production server, causing an outage. what should you have Done to prevent This, and what is your responsibility Now?

A black box penetration test is a security assessment in which the tester begins with limited knowledge of the target system's internal design. The tester evaluates the system from an external perspective, similar to how an outside attacker might approach it.

A denial-of-service (DOS) condition occurs when a system becomes unable to provide normal service because its resources are exhausted or its operations are disrupted. when a penetration test causes an outage on a live production server, the tester must immediately prioritize service restoration, communication and accountability.

Problem understanding :-

* interruption of services for customers and employees
* financial loss due to unavailable business applications.
* Loss of customer trust and damage to organization's reputation
* increased workload for the IT and incident-response teams.
* possible contractual or legal consequences.

Although the outage was accidental, I remain responsible for reporting my actions accurately and cooperating with the client to minimize harm.

Preventive Measures:-

* Define the scope and prohibited activities
* Conduct risk assessment
* use controlled testing methods
* Establish testing limits
* prepare emergency procedures
* Monitor system behaviour
* Test in a non-production environment when appropriate

Responsibilities:-

* stop the activity immediately

I would immediately notify the designated emergency contact and incident-response team. The notification should explain what happened, when it occured, which activity was involved, and what effects I observed.

*cooperate with recovery efforts

I would provide the information needed by the client's technical team to investigate and restore service. I would follow the client's recovery procedures and avoid making independent changes to the production server without authorization.

* Preserve accurate evidence

I would preserve relevant timestamps, test logs, commands or requests used, and observed responses where available and permitted. I would not delete or alter records to conceal the incident.

(4) A client Asks you to test their systems but insists you not inform their IT Department, wanting to test the team's Real-world Detection capability. what Ethical and practical Risks Does this Create, and how would you structure the Engagement to protect yourself?

A red team exercise is a controlled security activity designed to simulate realistic attacks and evaluate an organization's ability to detect, prevent and respond to them. one purpose of this exercise is to determise whether the security team can identify suspicious activities without being informed in advance

However, conducting a security test without informing the IT department creates ethical, legal and operational risks. Therefore the exercise must have proper authorization, clear boundaries, and safeguards.

Problem understanding:-

In this scenario, a client requests that i tests its systems without informing the IT department. The client wants to evaluate the team's real-world detection capability.

* The IT department may mistake the exercise for a genuine cyberattack.
* security controls may initiate emergency procedures unnecessarily
* sensitive information may be exposed during testing
* unclear authorization may create legal disputes or contractual Problems.

Ethical Risks :-

* Lack of Transperancy

If the exercise is conducted without an approved plan, employees and security personnel may not understand the purpose of the activity. This can create confusion and unnecessary panic.

* Risk of causing harm

Simulated attacks can accidentally disrupt systems, expose confidential information, or affect customers. The tester must avoid unnecessary harm and use only approved techniques.

* Misuse of authorization

A request from an individual client representative may not necessarily establish authority over every system involved. The tester must verify that the person approving the engagement has the appropriate authority.

* confidentiality and privacy

The exercise may encounter personal, financial, or business-sensitive information. Such information must be protected and must not be accessed or collected beyond what is necessary and authorized.

Practical Risks :-

* false alarms and incident escalation

* Business disruption

* Interference with incident response

* conflicts with other security activities

* unclear responsibility

⑤ you are asked to perform a Red-team exercise versus a vulnerability Assessment. using a Real-world scenario of a Bank wanting to test physical and Digital Security, Explain How your Approach, Ethics, and Rules of Engagement would differ b/w the two.

Organizations use different security assessment methods to identify weakness and evaluate their ability to resist cyberattacks. Two important methods are red-team exercises and vulnerability assessments.

A vulnerability assessment identifies, evaluates, and prioritizes security weakness in systems and infrastructure. A red-team exercise simulates realistic attack scenario to evaluate how effectively an organization's security controls and personnel prevent, detect, and respond to those activities

Real-world scenario :-

Suppose a bank wants to evaluate the security of its branches, ATM's, online banking application, internal network and customer information systems.

The bank is concerned about unauthorized physical access, weak application security, outdated software, phishing attacks and the ability of its security team to detect suspicious activity

The may conduct vulnerability assessment to identify known weakness to evaluate

Vulnerability Assessment :-

* objective

The main objective is to identify and prioritize security weakness before attackers can exploit them

* Approach

I would examine the bank's approved systems and infrastructure using authorized scanning tools, configuration reviews, and security checks. The assessment may cover network devices, web applications, server configuration, software versions, and physical access controls.

* physical security Assessment

I would review authorized physical security controls, including access card systems, visitor management, locks, surveillance coverage and procedures for securing server rooms.

* Rules of Engagement

The rules should identify the approved assets, assessment techniques, scanning limits, testing period, data-handling requirements, and reporting procedures.

Red team exercise :-

* objective, Approach
* Digital security testing
* physical security testing
* Ethical consideration
* Rules of Engagement.